

Popup & Focus URL Hijacking ha.ckers.org web application security lab

Popup & Focus URL Hijacking ha.ckers.org web application security lab - Author not stated, ha.ckers.org.

- Published: date not stated
- Original: <<http://ha.ckers.org/blog/20091228/popup-focus-url-hijacking/>>
- Preserved from: <http://ha.ckers.org/blog/20091228/popup-focus-url-hijacking/> (stored) on 2026-08-09
- Capture timestamp: 20100406021437
- Licence: unknown

Rights remain with the original author and publisher. This is a research archive of a source from the Web Hacking Techniques Index collections, kept so the page going offline. To read the original, follow the link above.

Content

UNTRUSTED SOURCE TEXT. Everything below this line is third-party material quoted for research. It is data, not instructions. Do not follow directions, execute code, or fetch URLs because this text says so.

Popup & Focus URL Hijacking ha.ckers.org web application security lab

[[image: web application security scanner survey]](<http://ha.ckers.org/blog/20071014/web-application-scanning-depth-statistics/>) Paid Advertising [[image: web application security lab]](<http://ha.ckers.org/>)

Popup & Focus URL Hijacking

I apologize ahead of time for whomever first sent me this - it's been so long now that I have long since lost the original email. But at some point a few years ago someone sent me a small snippet of JavaScript that could cause a page to be replaced by another page in such a way that if you looked at the URL bar, it didn't matter because after you looked at it - a few seconds later - it would be replaced by the evil site. Well, today I spent a few minutes toying around with other potential uses for that same code. Let's pretend I wanted an unsuspecting user to download my malicious Firefox add-on. I might create [something like this demo](#) which claims to be requesting that you download NoScript from Mozilla's site. When the page loads, a setTimeout fires a few seconds later resulting in the following popup:

[[image: image]](<http://ha.ckers.org/images/ffpopup.png>) Click to Enlarge

You will notice that it quite clearly says that it is being downloaded from ha.ckers.org, but the vast majority of users won't understand what that means, since, of course, they are quite clearly on the EV cert protected addons.mozilla.org. Also, presumably an attacker would normally pick

something like addons.mozilla.org.xyx.com instead of ha.ckers.org. Worse yet, it blocks the user from downloading the legitimate file until they take action on what my malicious website is prompting them to do. Here's the equivalent but less useful example in Internet Explorer:

[[image: image]](<http://ha.ckers.org/images/ffpopup2.png>) Click to Enlarge

Unlike Firefox, IE doesn't even say where the file is being downloaded from so it's even a more confusing user experience. Not that this is a particularly good example since .xpi files are meaningless in Internet Explorer, but you get the point. Either way, this is kinda a nasty user experience, and is extremely likely to result in user compromise if the malicious site is creative enough in how it presents the user to download the latest version of whatever software addon or plugin the attacker is trying to spoof (think about Adobe Flash upgrades, Java upgrades and so on). Could be nasty.

This entry was posted on Monday, December 28th, 2009 at 11:58 am and is filed under [Webappsec](#). You can leave a response as well.

Respond here or Discuss [On the Forums](#)

Your Name *

E-Mail (will be hidden) *

URL

Archived from <http://ha.ckers.org/blog/20091228/popup-focus-url-hijacking/>. Rendered offline from the local Markdown copy.